CyberTrust KSA Platform: Functional Requirements Specification

Document Version: 1.0
Date: February 20, 2026
Prepared by: Manus AI
Target Audience: Product Managers, Business Analysts, Stakeholders, QA Teams

---

1. Executive Summary

This document defines the complete functional requirements for the CyberTrust KSA platform, an AI-driven cybersecurity compliance ecosystem designed to revolutionize NCA (National Cybersecurity Authority) compliance in Saudi Arabia. The platform encompasses **51 consolidated functionalities** organized into four categories, transforming the traditional 5-day manual audit process into a streamlined 2-hour automated experience.

The functional requirements specify **what** the system must do from a user perspective, complementing the technical requirements document that defines **how** the system will be built. This specification serves as the authoritative source for feature development, user acceptance testing, and stakeholder alignment.

---

2. Platform Overview

2.1 Platform Purpose

CyberTrust KSA addresses the critical pain point of manual, time-consuming NCA compliance assessments by providing an intelligent, automated platform that:

- Analyzes cybersecurity policies and technical configurations using AI/NLP
- Automatically collects evidence from cloud providers and security tools

- Guides vendors through compliance requirements with a Virtual CISO chatbot
- Enables fast-track auditor partnerships for 2-hour certification
- Provides continuous compliance monitoring to maintain perpetual readiness
- Integrates legal, technical, and operational compliance requirements

2.2 Target Users

User Role	Description	Primary Use Cases
Vendor/Organization	Companies seeking NCA compliance certification	Self-assessment, evidence upload, gap remediation
Auditor	Authorized NCA auditing firms	Evidence review, assessment approval, certification
Compliance Officer	Internal compliance team members	Monitoring, reporting, policy management
CISO/Security Manager	Chief Information Security Officers	Risk oversight, executive dashboards, strategic planning
Administrator	Platform administrators	User management, system configuration, integration setup
Procurement Officer	Government/semi-government buyers	Vendor compliance verification, score checking
Training Manager	HR/training coordinators	Employee training tracking, certification management

2.3 Functionality Categories

The 51 functionalities are organized into four categories:

- **Category A (Core):** 13 foundational features from the original platform concept
- **Category B (Strategic):** 10 market-driven enhancements for competitive differentiation
- **Category C (Advanced):** 13 technical capabilities for operational excellence
- **Category D (Missing/New):** 15 critical gaps identified for market dominance

---

3. Category A: Core Functionalities (13 Features)

3.1 A1: AI Evidence Analyzer (NLP)

Priority: Critical | **Phase:** 1

3.1.1 Functional Description

The AI Evidence Analyzer uses Natural Language Processing to automatically read, understand, and analyze cybersecurity policy documents, network diagrams, disaster recovery plans, and other compliance evidence. The system cross-references document content with NCA control requirements and identifies missing clauses or gaps.

3.1.2 User Stories

US-A1-001: As a vendor, I want to upload my information security policy PDF so that the system can automatically analyze it against NCA ECC requirements.

US-A1-002: As a compliance officer, I want to see which specific NCA controls are addressed by my uploaded policies so that I can identify gaps.

US-A1-003: As a vendor, I want the system to highlight missing clauses in my policies so that I know exactly what to add.

US-A1-004: As a vendor, I want to upload documents in both Arabic and English so that the system can analyze them regardless of language.

3.1.3 Acceptance Criteria

- System accepts PDF, DOCX, and TXT file formats up to 50MB
- Analysis completes within 60 seconds for documents up to 100 pages
- System identifies at least 90% of relevant NCA control mappings (validated against expert review)
- System provides specific clause-level feedback, not just document-level assessment
- Arabic text analysis achieves same accuracy as English (>85% precision)
- System generates a downloadable gap analysis report in PDF format

- Analysis results include confidence scores for each identified mapping

3.1.4 Business Rules

- Only authenticated users can upload documents
- Documents are encrypted at rest and in transit
- Analysis results are saved to user's assessment history
- Users can re-analyze documents after making edits
- Maximum 100 document uploads per tenant per day (rate limiting)

3.2 A2: Automated Technical Integrations

Priority: Critical | **Phase:** 1

3.2.1 Functional Description

The platform integrates directly with major cloud providers (AWS, Azure, AliBaba Cloud, STC Cloud) and security tools (CrowdStrike, Fortinet) via API connections to automatically collect technical evidence such as firewall rules, encryption status, MFA configuration, and security logs. This eliminates manual screenshot submissions and ensures real-time accuracy.

3.2.2 User Stories

US-A2-001: As a vendor, I want to connect my AWS account so that the system can automatically verify my security configurations.

US-A2-002: As a vendor, I want the system to check if MFA is enabled on my cloud accounts so that I don't have to provide manual screenshots.

US-A2-003: As a compliance officer, I want to see real-time status of our cloud security settings so that I can ensure continuous compliance.

US-A2-004: As a vendor, I want to authorize the platform to access my CrowdStrike dashboard so that endpoint protection evidence is collected automatically.

3.2.3 Acceptance Criteria

- System supports OAuth 2.0 / API key authentication for all listed cloud providers

- Integration setup wizard guides users through connection process in < 5 minutes
- System collects evidence for at least 20 common NCA technical controls automatically
- Evidence collection runs on a configurable schedule (hourly, daily, weekly)
- System displays last sync timestamp and status (success/failure) for each integration
- Failed integrations trigger email alerts to the user
- Users can manually trigger evidence collection on-demand
- System validates API credentials before saving integration

3.2.4 Business Rules

- Users must have appropriate permissions in their cloud accounts to authorize integration
- API credentials are encrypted using AES-256 before storage
- System automatically retries failed evidence collection up to 3 times
- Integration can be paused or deleted by the user at any time
- Evidence collected via API is marked with “automated” collection method in the database

---

3.3 A3: Interactive Virtual CISO Chatbot

Priority: High | **Phase:** 1

3.3.1 Functional Description

An AI-powered chatbot assistant that guides vendors through the compliance assessment process, explains complex NCA controls in simple language, provides instant compliance templates, and answers vendor questions in real-time. The chatbot supports both Arabic and English and maintains conversation context.

3.3.2 User Stories

US-A3-001: As a small business owner with no security team, I want to ask the chatbot what “data classification” means so that I can understand the requirement.

US-A3-002: As a vendor, I want the chatbot to provide me with a template incident response policy so that I can quickly create the required document.

US-A3-003: As a vendor, I want to chat in Arabic so that I can communicate in my preferred language.

US-A3-004: As a compliance officer, I want the chatbot to remember our previous conversation so that I don't have to repeat context.

3.3.3 Acceptance Criteria

- Chatbot responds within 5 seconds for 95% of queries
- Chatbot provides relevant answers for at least 80% of compliance-related questions (measured by user satisfaction ratings)
- Chatbot detects user language (Arabic/English) automatically and responds in the same language
- Chatbot maintains conversation history for the current session
- Chatbot can provide downloadable templates for common policies (at least 10 policy types)
- Users can rate chatbot responses (thumbs up/down) for continuous improvement
- Chatbot escalates to human support when it cannot answer a question (after 3 failed attempts)

3.3.4 Business Rules

- Chatbot is available $^{24}/_{7}$ with no downtime for maintenance
- Conversation history is retained for 90 days for audit purposes
- Chatbot does not provide legal advice (disclaimer displayed)
- Users must be authenticated to access the chatbot
- Chatbot responses are logged for quality assurance and AI model training

---

3.4 A4: Dynamic Risk Scoring

Priority: Critical | **Phase:** 1

3.4.1 Functional Description

An intelligent categorization system that automatically determines a vendor's risk level (General Services vs. Higher-Risk) based on an initial questionnaire. The system dynamically adjusts which NCA controls are applicable and generates a personalized compliance roadmap with estimated timeline.

3.4.2 User Stories

US-A4-001: As a vendor, I want to answer a short questionnaire so that the system can determine which NCA controls apply to my business.

US-A4-002: As a vendor, I want to see my risk category (General/High-Risk) so that I understand the level of compliance required.

US-A4-003: As a vendor, I want the system to show me only the controls relevant to my risk level so that I don't waste time on unnecessary requirements.

US-A4-004: As a CISO, I want to see a compliance roadmap with estimated timelines so that I can plan resources accordingly.

3.4.3 Acceptance Criteria

- Questionnaire contains no more than 10 questions and takes < 5 minutes to complete
- System categorizes vendors into "General Services" or "Higher-Risk" based on responses
- Risk categorization aligns with NCA guidelines (validated by compliance experts)
- System displays a personalized list of applicable controls (e.g., 50 controls for General, 80 for High-Risk)
- Compliance roadmap shows estimated time to complete each control
- Users can review and modify their questionnaire responses if business context changes
- System provides a risk score (0-100) in addition to the category

3.4.4 Business Rules

- Risk categorization is final once an assessment is submitted for auditor review

- Users can retake the questionnaire to update their risk profile (triggers new assessment)
- System logs risk category changes for audit trail
- Higher-risk vendors are flagged for additional scrutiny by auditors

---

3.5 A5: Fast-Track Partnership Model

Priority: Critical | **Phase:** 1

3.5.1 Functional Description

A workflow system that enables authorized NCA auditing firms to access AI-pre-verified evidence through a dedicated auditor portal. Auditors can review pre-mapped evidence, see AI confidence scores, and approve assessments with one-click workflows, reducing audit time from 5 days to 2 hours.

3.5.2 User Stories

US-A5-001: As an auditor, I want to log into a dedicated portal so that I can review vendor assessments assigned to me.

US-A5-002: As an auditor, I want to see evidence pre-mapped to each NCA control so that I don't have to hunt for documents.

US-A5-003: As an auditor, I want to see AI confidence scores for each control so that I can prioritize my review on low-confidence items.

US-A5-004: As an auditor, I want to approve or reject an assessment with a single click so that I can process assessments quickly.

US-A5-005: As a vendor, I want to submit my completed assessment to my chosen auditor so that I can get certified.

3.5.3 Acceptance Criteria

- Auditor portal displays a dashboard with all assigned assessments
- Each assessment shows overall compliance score, number of controls, and evidence count

- Auditors can drill down into individual controls to review evidence
- System displays AI confidence score (0-100%) for each control
- Auditors can flag anomalies or request additional evidence
- One-click approval generates a preliminary certification (pending official NCA submission)
- System tracks audit time from assignment to approval (target: < 2 hours)
- Revenue sharing calculations are automated based on approved assessments

3.5.4 Business Rules

- Only authorized auditing firms can access the auditor portal
- Auditors can only view assessments assigned to their firm
- Vendors select their preferred auditor from a list of platform partners
- Auditor approval is required before a CyberTrust Readiness Badge is issued
- Platform takes a percentage of the audit fee (defined in partnership agreement)

3.6 A6: CyberTrust Real-Time Readiness Badge

Priority: High | **Phase:** 1

3.6.1 Functional Description

A proprietary digital badge issued by the platform after AI pre-assessment and auditor review (but before official NCA certification). The badge serves as a preliminary compliance indicator, enabling vendors to begin procurement conversations while awaiting final NCA approval.

3.6.2 User Stories

US-A6-001: As a vendor, I want to receive a digital badge after my assessment is approved so that I can demonstrate readiness to potential clients.

US-A6-002: As a procurement officer, I want to verify a vendor's CyberTrust badge via a URL so that I can confirm their compliance status.

US-A6-003: As a vendor, I want to embed my badge on my website so that clients can see my compliance status.

US-A6-004: As a vendor, I want my badge to show an expiration date so that clients know it's current.

3.6.3 Acceptance Criteria

- Badge is automatically generated after auditor approval
- Badge includes vendor name, issue date, expiration date (1 year), and unique verification code
- Badge is available in digital format (PNG, SVG) and embeddable HTML widget
- Public verification URL allows anyone to check badge validity without login
- Badge displays compliance score and framework (e.g., "NCA ECC - 92% Compliant")
- Expired badges are automatically revoked and verification URL shows "Expired" status
- Vendors can download badge certificate in PDF format

3.6.4 Business Rules

- Badge is valid for 1 year from issue date
- Badge does not replace official NCA certification (disclaimer displayed)
- Badge is revoked if continuous monitoring detects compliance drift
- Vendors must re-assess annually to renew badge
- Badge verification URL is publicly accessible (no authentication required)

3.7 A7: AI Triage System

Priority: High | **Phase:** 1

3.7.1 Functional Description

An automated onboarding workflow that determines a vendor's compliance requirements in 10 minutes through a 5-question intelligent assessment. The system

automatically classifies risk level, generates a customized NCA control checklist, and provides a personalized compliance roadmap with estimated timeline.

3.7.2 User Stories

US-A7-001: As a new vendor, I want to complete a quick assessment so that I can understand what compliance requirements apply to me.

US-A7-002: As a vendor, I want to see a customized checklist of NCA controls so that I know exactly what I need to do.

US-A7-003: As a vendor, I want to see an estimated timeline for achieving compliance so that I can plan accordingly.

US-A7-004: As a vendor, I want the system to map my requirements to the appropriate NCA framework (ECC, TCC, CSCC) so that I'm following the right standards.

3.7.3 Acceptance Criteria

- Assessment contains exactly 5 questions and takes < 10 minutes to complete
- System generates a customized control checklist within 30 seconds of submission
- Checklist is organized by priority (Critical, High, Medium, Low)
- System provides estimated time to complete each control (e.g., "2 hours", "1 week")
- Total estimated timeline is displayed prominently (e.g., "Estimated 6-8 weeks to full compliance")
- System maps vendor to the correct NCA framework based on business type
- Vendors can download the roadmap as a PDF or Excel file

3.7.4 Business Rules

- Triage assessment is the first step in the onboarding process (required before full assessment)
- Assessment results are saved to the vendor's profile
- Vendors can retake the assessment if their business changes

- System uses machine learning to improve timeline estimates based on historical data

---

3.8 A8: Automated Evidence Gathering

Priority: Critical | **Phase:** 2

3.8.1 Functional Description

An orchestration layer that automatically collects evidence from connected cloud providers, security tools, HR systems, and other integrated platforms on a scheduled basis. The system maps collected evidence to relevant NCA controls, validates completeness, and stores evidence in an encrypted repository with version control.

3.8.2 User Stories

US-A8-001: As a vendor, I want the system to automatically collect evidence from my cloud accounts daily so that I don't have to manually upload screenshots.

US-A8-002: As a compliance officer, I want to see which evidence has been collected and which is still missing so that I can prioritize my work.

US-A8-003: As a vendor, I want evidence to be automatically mapped to the correct NCA controls so that I don't have to do it manually.

US-A8-004: As a vendor, I want to schedule evidence collection to run during off-peak hours so that it doesn't impact system performance.

3.8.3 Acceptance Criteria

- System collects evidence from all connected integrations on a configurable schedule (hourly, daily, weekly)
- Evidence collection completes within 2 hours for typical vendor configurations
- System automatically maps evidence to at least 80% of applicable NCA controls
- Evidence repository displays collection timestamp, source, and mapped controls
- Users can manually trigger evidence collection on-demand
- System validates evidence completeness (e.g., checks if firewall rules export is empty)

- Failed collections trigger alerts and retry automatically up to 3 times

3.8.4 Business Rules

- Evidence is stored encrypted at rest (AES-256)
- Evidence is retained for 7 years for compliance purposes
- Users can delete evidence manually (with audit log entry)
- Evidence versions are tracked (users can view historical evidence)
- Maximum evidence file size: 100MB per file

3.9 A9: Gap Analysis & Remediation Engine

Priority: Critical | **Phase:** 2

3.9.1 Functional Description

An AI-powered system that identifies specific compliance gaps by analyzing uploaded policies, collected evidence, and assessment responses. The system provides actionable remediation guidance including AI-generated templates, step-by-step fix instructions, and progress tracking.

3.9.2 User Stories

US-A9-001: As a vendor, I want to see a list of all compliance gaps so that I know what needs to be fixed.

US-A9-002: As a vendor, I want the system to provide specific remediation steps for each gap so that I know how to fix it.

US-A9-003: As a vendor, I want to receive AI-generated policy templates to fill gaps so that I can quickly create missing documents.

US-A9-004: As a compliance officer, I want to track remediation progress so that I can report status to management.

3.9.3 Acceptance Criteria

- System identifies gaps at the control level (not just framework level)

- Gap analysis displays severity (Critical, High, Medium, Low) for each gap
- System provides at least 3 remediation options for each gap (e.g., “Create policy”, “Enable MFA”, “Configure firewall”)
- AI-generated templates are customized to the vendor’s industry and risk level
- Users can mark gaps as “Remediated” and upload supporting evidence
- System re-validates gaps after remediation (automatic or manual trigger)
- Progress dashboard shows percentage of gaps remediated over time

3.9.4 Business Rules

- Gaps are prioritized by NCA control priority (Critical controls first)
- Users cannot submit assessment for auditor review if Critical gaps remain
- Remediation templates are reviewed by compliance experts before being made available
- System logs all gap remediation actions for audit trail

3.10 A10: Auditor Handoff Package

Priority: High | **Phase:** 2

3.10.1 Functional Description

An automated report generation system that compiles a comprehensive, AI-verified compliance dossier for authorized auditors. The package includes all evidence, policy documents, gap analysis results, AI confidence scores, and pre-mapped evidence-to-control relationships in a standardized format.

3.10.2 User Stories

US-A10-001: As a vendor, I want to generate an auditor handoff package with one click so that I can submit it to my chosen auditor.

US-A10-002: As an auditor, I want to receive a standardized package so that I can quickly understand the vendor’s compliance posture.

US-A10-003: As an auditor, I want to see AI confidence scores for each control so that I can focus my review on low-confidence areas.

US-A10-004: As an auditor, I want to see anomalies flagged by the system so that I can investigate potential issues.

3.10.3 Acceptance Criteria

- Package generation completes within 5 minutes for typical assessments
- Package includes: executive summary, control-by-control assessment, all evidence files, gap analysis, AI verification summary
- Package is available in PDF format (for printing) and digital format (for online review)
- AI verification summary includes confidence scores (0-100%) for each control
- System flags anomalies such as missing evidence, low confidence scores, or conflicting data
- Package includes a table of contents and is organized by NCA control category
- Package is downloadable and shareable via secure link (password-protected)

3.10.4 Business Rules

- Package can only be generated after all Critical gaps are remediated
- Package includes a timestamp and version number
- Package is automatically sent to the assigned auditor via the platform
- Vendors can regenerate the package if they update evidence or policies

---

3.11 A11: Bilingual Framework Support

Priority: Critical | **Phase:** 1

3.11.1 Functional Description

Comprehensive Arabic and English language support across the entire platform, including user interface, NCA framework content, policy templates, reports, and AI chatbot. The system uses native Arabic cybersecurity terminology and provides RTL (right-to-left) text support for Arabic content.

3.11.2 User Stories

US-A11-001: As an Arabic-speaking user, I want to switch the platform interface to Arabic so that I can use it in my preferred language.

US-A11-002: As a vendor, I want to view NCA control descriptions in Arabic so that I can understand the requirements clearly.

US-A11-003: As a vendor, I want to generate compliance reports in Arabic so that I can share them with Arabic-speaking stakeholders.

US-A11-004: As a vendor, I want to upload Arabic policy documents and have them analyzed correctly so that I don't have to translate them.

3.11.3 Acceptance Criteria

- Platform supports full Arabic and English localization for all UI elements
- Users can switch language via a dropdown in the header (preference saved to profile)
- All NCA control descriptions are available in both Arabic and English
- Policy templates are available in both languages
- Reports can be generated in either language (user selectable)
- Arabic text is displayed with proper RTL formatting
- AI chatbot responds in the user's selected language
- Arabic NLP analysis achieves at least 85% accuracy compared to English

3.11.4 Business Rules

- Default language is determined by user's browser settings on first visit
- Language preference is saved to user profile and persists across sessions
- System uses official NCA Arabic terminology for consistency
- All user-generated content (policies, notes) can be entered in either language

---

3.12 A12: Cost-Effective Certification Model

Priority: Medium | **Phase:** 2

3.12.1 Functional Description

A scalable pricing model that offers competitive certification costs by enabling auditors to process 10x more clients through AI-driven efficiency gains. The platform supports tiered pricing (Basic, Professional, Enterprise), revenue sharing with auditor partners, and transparent fee structures.

3.12.2 User Stories

US-A12-001: As a small business, I want to see transparent pricing so that I can budget for compliance certification.

US-A12-002: As a vendor, I want to choose a subscription tier that matches my needs so that I don't pay for features I don't use.

US-A12-003: As an auditor, I want to see my revenue share from completed audits so that I can track my earnings.

US-A12-004: As a vendor, I want to receive volume discounts if I certify multiple subsidiaries so that I can save costs.

3.12.3 Acceptance Criteria

- Platform offers at least 3 subscription tiers (Basic, Professional, Enterprise)
- Pricing page clearly lists features included in each tier
- Users can upgrade or downgrade tiers at any time (prorated billing)
- Auditor partners receive automated revenue share payments within 30 days of assessment approval
- Volume discounts are automatically applied for multi-entity subscriptions (10% for 5+ entities)
- Platform displays total cost savings compared to traditional consulting (e.g., "Save 60% vs. traditional audit")
- Free trial available for 14 days (no credit card required)

3.12.4 Business Rules

- Basic tier includes: AI Evidence Analyzer, Virtual CISO, up to 5 integrations

- Professional tier adds: Continuous Monitoring, unlimited integrations, priority support
- Enterprise tier adds: Multi-entity support, dedicated account manager, custom integrations
- Revenue share with auditors: Platform retains 30%, auditor receives 70%
- Pricing is in Saudi Riyals (SAR) with USD conversion available

---

3.13 A13: Speed-to-Certification Optimization

Priority: Medium | **Phase:** 2

3.13.1 Functional Description

Workflow optimization logic that identifies the shortest path to compliance by analyzing the vendor's current state, prioritizing critical controls, identifying blockers, and providing fast-track wizards for common scenarios. The system uses AI to predict completion time and suggest optimal sequences.

3.13.2 User Stories

US-A13-001: As a vendor with a tight deadline, I want the system to show me the fastest path to compliance so that I can meet my procurement deadline.

US-A13-002: As a vendor, I want the system to identify blockers (e.g., missing integrations) so that I can address them immediately.

US-A13-003: As a vendor, I want to use fast-track wizards for common controls (e.g., MFA setup) so that I can complete them quickly.

US-A13-004: As a compliance officer, I want to see predicted completion time so that I can manage stakeholder expectations.

3.13.3 Acceptance Criteria

- System analyzes vendor's current compliance state and generates an optimized roadmap
- Roadmap prioritizes controls by impact on overall compliance score

- System identifies blockers (e.g., “AWS integration not connected”) and suggests fixes
- Fast-track wizards are available for at least 10 common controls
- System predicts completion time based on historical data from similar vendors
- Users can choose between “Fastest Path” and “Comprehensive Path” roadmaps
- System updates predicted completion time as vendor makes progress

3.13.4 Business Rules

- Critical controls are always prioritized first (cannot be skipped)
- Fast-track wizards provide step-by-step guidance with screenshots
- System uses machine learning to improve time predictions based on actual completion data
- Vendors can manually reorder non-critical controls if needed

---

4. Category B: Strategic Functionalities (10 Features)

4.1 B1: Legal & Contractual Risk Management Module

Priority: Critical | **Phase:** 2

4.1.1 Functional Description

A comprehensive legal risk management system that generates legally enforceable cybersecurity contract clauses, board-level governance reports, incident response decision documentation, and breach liability calculations. The module includes NLP-based contract analysis and a legal counsel collaboration workspace.

4.1.2 User Stories

US-B1-001: As a legal counsel, I want to generate cybersecurity contract clauses automatically so that I can include them in vendor agreements.

US-B1-002: As a CISO, I want to create board-level governance reports so that I can demonstrate compliance to the board of directors.

US-B1-003: As a compliance officer, I want to document incident response decisions so that I can demonstrate due diligence in case of a breach.

US-B1-004: As a legal counsel, I want to analyze third-party contracts for cybersecurity clauses so that I can identify gaps.

US-B1-005: As a CFO, I want to calculate potential breach liability so that I can assess financial risk.

4.1.3 Acceptance Criteria

- System provides a library of at least 20 standard cybersecurity contract clauses (customizable)
- Board report generator creates executive-level reports with compliance status, risk metrics, and recommendations
- Incident response documentation includes timeline, decisions made, evidence of notification, and lessons learned
- Contract analysis tool identifies missing cybersecurity clauses and suggests additions
- Breach liability calculator estimates financial impact based on data type, volume, and jurisdiction
- Legal counsel can collaborate with compliance team via shared workspace (comments, approvals)
- All generated documents are downloadable in PDF and DOCX formats

4.1.4 Business Rules

- Contract clauses are reviewed by legal experts before being added to the library
- Board reports include a disclaimer that they are for internal use only
- Incident response documentation is stored encrypted and retained for 7 years
- Breach liability calculations are estimates only (not legal advice)

4.2 B2: Continuous Compliance Monitoring

Priority: Critical | **Phase:** 2

4.2.1 Functional Description

A real-time monitoring system that continuously checks compliance status by integrating with cloud providers, security tools, and SOC platforms. The system detects compliance drift, sends proactive alerts, maintains automated audit trails, and provides live dashboards with KRIs/KPIs. Includes a mobile app for executive monitoring.

4.2.2 User Stories

US-B2-001: As a compliance officer, I want to see real-time compliance status on a dashboard so that I know if we're still compliant.

US-B2-002: As a CISO, I want to receive alerts when compliance drift is detected so that I can take immediate action.

US-B2-003: As a compliance officer, I want to see a history of compliance changes over time so that I can identify trends.

US-B2-004: As a CISO, I want to monitor compliance status on my mobile device so that I can stay informed while traveling.

US-B2-005: As an auditor, I want to see continuous monitoring logs so that I can verify that compliance is maintained between audits.

4.2.3 Acceptance Criteria

- Dashboard displays real-time compliance score (updated every 15 minutes)
- System monitors at least 30 critical controls continuously ($^{24}/_{7}$)
- Compliance drift alerts are sent via email, SMS, and mobile push notification within 5 minutes of detection
- Dashboard includes KRIs (Key Risk Indicators) such as "Controls at Risk", "Evidence Expiring Soon"
- Dashboard includes KPIs (Key Performance Indicators) such as "Time to Remediate Gaps", "Compliance Score Trend"
- Mobile app (iOS/Android) provides read-only access to dashboard and alerts
- System maintains an immutable audit trail of all compliance changes
- Users can configure alert thresholds and notification preferences

4.2.4 Business Rules

- Continuous monitoring is available only for Professional and Enterprise tiers
- System checks cloud integrations every 15 minutes for drift detection
- Alerts are prioritized by severity (Critical, High, Medium, Low)
- Users can snooze alerts for up to 24 hours (with justification required)
- Mobile app requires biometric authentication (fingerprint/face ID)

4.3 B3: Supply Chain Risk Intelligence

Priority: High | **Phase:** 3

4.3.1 Functional Description

A deep assessment system for third-party vendor risk that maps the entire vendor ecosystem (including 4th and 5th party relationships), analyzes risk propagation, visualizes vendor interdependencies, assesses geopolitical risk, maps data flows, monitors dark web for compromised credentials, and tracks vendor financial health.

4.3.2 User Stories

US-B3-001: As a CISO, I want to map all my third-party vendors so that I can understand my supply chain risk.

US-B3-002: As a risk manager, I want to see which vendors have access to sensitive data so that I can prioritize risk assessments.

US-B3-003: As a compliance officer, I want to see if any of my vendors' credentials have been found on the dark web so that I can take action.

US-B3-004: As a CISO, I want to visualize vendor interdependencies so that I can understand cascading risk.

US-B3-005: As a procurement officer, I want to see vendor financial health scores so that I can assess business continuity risk.

4.3.3 Acceptance Criteria

- System allows users to add unlimited vendors with details (name, type, data access level, contract dates)
- Vendor ecosystem map visualizes relationships (parent-child, supplier-subcontractor) in a graph view
- Risk propagation analysis shows how a vendor breach could impact the organization
- Geopolitical risk assessment flags vendors in high-risk countries (based on configurable criteria)
- Data flow mapping shows which vendors have access to which data types (PII, financial, health)
- Dark web monitoring scans for vendor domain credentials daily and alerts if found
- Financial health score is calculated based on public financial data (if available) or user-provided assessment
- System supports vendor lifecycle management (onboarding, assessment, offboarding)

4.3.4 Business Rules

- Vendor risk assessments must be updated at least annually
- High-risk vendors require additional documentation (e.g., SOC 2 report)
- Dark web monitoring is available only for Enterprise tier
- Vendor data is encrypted and access is restricted to authorized users only

---

4.4 B4: PDPL Integration Module

Priority: High | **Phase:** 2

4.4.1 Functional Description

A dedicated module for Personal Data Protection Law (PDPL) compliance that integrates with NCA frameworks to provide unified compliance management. Features include data controller registration verification, sensitive data processing inventory,

cross-border data transfer compliance checking, data subject rights management, Privacy Impact Assessment (PIA) automation, and consent management tracking.

4.4.2 User Stories

US-B4-001: As a Data Protection Officer (DPO), I want to verify that we're registered as a data controller so that we comply with PDPL.

US-B4-002: As a DPO, I want to maintain an inventory of all personal data we process so that I can demonstrate compliance.

US-B4-003: As a compliance officer, I want to check if our cross-border data transfers comply with PDPL so that I can avoid penalties.

US-B4-004: As a DPO, I want to manage data subject access requests so that I can respond within the required timeframe.

US-B4-005: As a DPO, I want to automate Privacy Impact Assessments so that I can complete them efficiently.

4.4.3 Acceptance Criteria

- System verifies data controller registration status (manual input or API integration if available)
- Data processing inventory includes: data type, purpose, legal basis, retention period, recipients
- Cross-border transfer checker flags transfers to non-approved countries and suggests safeguards (e.g., standard contractual clauses)
- Data subject rights management workflow supports: access requests, rectification, erasure, portability
- PIA automation generates a PIA report based on questionnaire responses (aligned with PDPL requirements)
- Unified dashboard shows both NCA and PDPL compliance status side-by-side
- Consent management tracks: consent obtained, purpose, date, withdrawal requests
- Privacy policy generator creates PDPL-compliant privacy policies

4.4.4 Business Rules

- PDPL module is available only for Professional and Enterprise tiers
- Data subject requests must be responded to within 30 days (system sends reminders)
- PIA is required for high-risk data processing activities
- Consent records are retained for 7 years after withdrawal

4.5 B5: AI Threat Intelligence & Predictive Risk Analytics

Priority: Medium | **Phase:** 3

4.5.1 Functional Description

An advanced threat intelligence system that provides Saudi-specific threat feeds, industry-specific threat profiles, Arabic language threat intelligence, nation-state actor tracking, ransomware group monitoring, ML-based breach likelihood prediction, attack path simulation, financial risk quantification, peer benchmarking, and automated threat response recommendations.

4.5.2 User Stories

US-B5-001: As a CISO, I want to see threats specific to Saudi Arabia so that I can prioritize defenses.

US-B5-002: As a security analyst, I want to see threats targeting my industry (e.g., oil & gas) so that I can prepare accordingly.

US-B5-003: As a CISO, I want to see the likelihood of a breach based on our current security posture so that I can justify security investments.

US-B5-004: As a risk manager, I want to see attack path simulations so that I can understand how an attacker might compromise our systems.

US-B5-005: As a CFO, I want to see the financial impact of a potential breach so that I can assess risk vs. investment.

4.5.3 Acceptance Criteria

- Threat intelligence feed is updated daily with Saudi-specific threats
- System provides threat profiles for at least 10 industries (oil & gas, finance, healthcare, government, etc.)
- Arabic language threat intelligence is translated and contextualized for Saudi users
- Nation-state actor tracking identifies threats from specific countries (based on public intelligence)
- Ransomware group monitoring tracks active groups and their tactics
- Breach likelihood prediction uses ML model trained on historical breach data (score 0-100%)
- Attack path simulation visualizes potential attack vectors based on current security gaps
- Financial risk quantification estimates potential breach costs (data loss, downtime, fines, reputation)
- Peer benchmarking compares organization's risk score to industry average
- System provides automated recommendations (e.g., "Enable MFA to reduce breach likelihood by 40%")

4.5.4 Business Rules

- Threat intelligence is available only for Enterprise tier
- Breach likelihood predictions are updated weekly
- Attack path simulations are run on-demand (not continuously)
- Financial risk estimates are based on industry averages and should be validated by CFO

4.6 B6: Regulatory Change Management

Priority: Medium | **Phase:** 3

4.6.1 Functional Description

An automated system that tracks NCA regulatory updates, analyzes impact on the organization, performs gap analysis against new requirements, generates implementation roadmaps, tracks regulatory deadlines, supports policy-as-code, provides infrastructure-as-code NCA templates, automates compliance testing, and supports multi-framework compliance (SAMA, ISO 27001, NIST, SOC 2).

4.6.2 User Stories

US-B6-001: As a compliance officer, I want to be notified when NCA releases new regulations so that I can assess the impact.

US-B6-002: As a compliance officer, I want to see which new requirements apply to my organization so that I can plan implementation.

US-B6-003: As a CISO, I want to see a gap analysis against new requirements so that I know what needs to change.

US-B6-004: As a compliance officer, I want to track regulatory deadlines so that I don't miss compliance dates.

US-B6-005: As a DevOps engineer, I want to use infrastructure-as-code templates that are NCA-compliant so that I can deploy secure infrastructure quickly.

4.6.3 Acceptance Criteria

- System monitors NCA website and other official sources for regulatory updates (daily)
- Users receive email notifications within 24 hours of a new regulation being published
- Impact analysis shows which controls are affected and whether they apply to the organization
- Gap analysis compares current compliance state to new requirements
- Implementation roadmap provides step-by-step guidance with estimated timelines
- Regulatory deadline tracker shows upcoming deadlines with countdown timers

- Policy-as-code framework allows policies to be defined in YAML/JSON and automatically enforced
- Infrastructure-as-code templates are available for common cloud configurations (AWS, Azure)
- Automated compliance testing runs daily to verify policy enforcement
- Multi-framework support allows mapping between NCA, SAMA, ISO 27001, NIST, SOC 2

4.6.4 Business Rules

- Regulatory updates are verified by compliance experts before being published in the platform
- Impact analysis is based on the organization's risk profile and industry
- Policy-as-code and infrastructure-as-code are available only for Enterprise tier
- Automated compliance testing requires integration with cloud providers

---

4.7 B7: Incident Response & Crisis Management Platform

Priority: Medium | **Phase:** 3

4.7.1 Functional Description

A comprehensive incident management system that automates incident detection and classification, executes incident response playbooks, automates stakeholder notifications, preserves evidence with chain-of-custody, provides regulatory communication templates, includes a 72-hour NCA reporting countdown timer, auto-populates NCA notification forms, supports crisis simulations and tabletop exercises, integrates with business continuity plans, and tracks RTO/RPO.

4.7.2 User Stories

US-B7-001: As a security analyst, I want to log a security incident so that the response process is initiated automatically.

US-B7-002: As an incident responder, I want to follow a playbook so that I don't miss critical steps.

US-B7-003: As a CISO, I want to be notified immediately when a critical incident occurs so that I can escalate if needed.

US-B7-004: As a compliance officer, I want to see a countdown timer for NCA notification so that I don't miss the 72-hour deadline.

US-B7-005: As a CISO, I want to run tabletop exercises so that my team is prepared for real incidents.

4.7.3 Acceptance Criteria

- System allows users to create incidents with details (title, description, severity, type)
- Incident classification is automated based on keywords and severity (Critical, High, Medium, Low)
- Playbook execution guides users through response steps with checkboxes and timers
- Stakeholder notifications are sent automatically via email, SMS, and mobile push (configurable)
- Evidence preservation captures logs, screenshots, and other artifacts with timestamps
- Chain-of-custody tracking records who accessed evidence and when
- Regulatory communication templates are available for NCA, PDPL, and other authorities
- 72-hour countdown timer is displayed prominently for incidents requiring NCA notification
- NCA notification form is auto-populated with incident details (users review before submission)
- Crisis simulation mode allows teams to practice incident response without affecting production data
- Business continuity integration shows RTO (Recovery Time Objective) and RPO (Recovery Point Objective) for affected systems

4.7.4 Business Rules

- Critical incidents trigger immediate notifications to CISO and compliance officer

- Incident response playbooks are customizable by organization
- Evidence is stored encrypted and access is logged for audit purposes
- NCA notification is required for incidents involving personal data breaches or critical infrastructure
- Tabletop exercises are available only for Enterprise tier

4.8 B8: Localization & Cultural Adaptation

Priority: Low | **Phase:** 4

4.8.1 Functional Description

Deep Saudi market localization including native Arabic interface with RTL optimization, Arabic NLP models for Saudi dialect, Arabic voice interface for Virtual CISO, Islamic calendar integration, Saudi business hours and holiday calendar, gender-segregated training options, Saudi data localization compliance, Absher/Muqeem integration for authentication, 24/7 Arabic technical support in KSA, Vision 2030 alignment reporting, and local content measurement for procurement.

4.8.2 User Stories

US-B8-001: As a Saudi user, I want to see dates in the Islamic calendar so that I can plan around religious holidays.

US-B8-002: As a Saudi user, I want to authenticate using my Absher account so that I don't have to create a new account.

US-B8-003: As a training manager, I want to offer gender-segregated training sessions so that I comply with cultural norms.

US-B8-004: As a procurement officer, I want to see local content percentage so that I can meet government procurement requirements.

US-B8-005: As a Saudi user, I want to use voice commands in Arabic so that I can interact with the platform hands-free.

4.8.3 Acceptance Criteria

- Platform displays dates in both Gregorian and Hijri (Islamic) calendars (user selectable)
- Saudi business hours (Sunday-Thursday) are used for scheduling and notifications
- Saudi holidays (Eid, National Day, etc.) are marked in the calendar
- Absher/Muqeem integration allows users to authenticate using their national ID
- Gender-segregated training options are available (separate sessions for male/female employees)
- Data localization checker verifies that all data is stored in KSA regions
- Arabic voice interface supports common commands (e.g., “Show my compliance score”)
- 24/7 Arabic technical support is available via chat, email, and phone
- Vision 2030 alignment report shows how the platform supports Saudi Vision 2030 objectives
- Local content measurement calculates percentage of Saudi-based services and employees

4.8.4 Business Rules

- Absher/Muqeem integration requires approval from Saudi Digital Government Authority
- Gender-segregated training is optional and configurable by organization
- Data localization is mandatory for government and semi-government entities
- Local content measurement is required for government procurement (minimum 30% local content)

4.9 B9: Blockchain Verification & Audit Trail

Priority: Low | **Phase:** 4

4.9.1 Functional Description

Immutable audit trail system using blockchain technology to record compliance activities, provide cryptographic timestamping, ensure tamper-proof evidence storage, support smart contracts for automated rule enforcement, enable distributed ledger for multi-party verification, issue blockchain-based digital certificates, support verifiable credentials for auditors/professionals, create a transparent compliance marketplace, implement a decentralized reputation system, and provide dispute resolution with immutable evidence.

4.9.2 User Stories

US-B9-001: As a vendor, I want my compliance activities recorded on blockchain so that they cannot be tampered with.

US-B9-002: As an auditor, I want to verify evidence authenticity using blockchain so that I can trust the data.

US-B9-003: As a vendor, I want to receive a blockchain-based certificate so that it cannot be forged.

US-B9-004: As a procurement officer, I want to verify a vendor's certificate on the blockchain so that I can confirm its authenticity.

US-B9-005: As a vendor, I want to use smart contracts to automatically enforce compliance rules so that I don't have to manually check.

4.9.3 Acceptance Criteria

- System records critical compliance activities on blockchain (evidence upload, assessment approval, certificate issuance)
- Each blockchain record includes a cryptographic hash, timestamp, and transaction ID
- Evidence files are hashed (SHA-256) and the hash is stored on blockchain for verification
- Smart contracts can be configured to enforce rules (e.g., "Require MFA for all users")
- Blockchain-based certificates include a QR code that links to the blockchain transaction

- Public verification portal allows anyone to verify certificate authenticity using transaction ID
- Verifiable credentials for auditors are issued on blockchain (tamper-proof)
- Compliance marketplace allows vendors to share templates and best practices (blockchain-verified)
- Decentralized reputation system tracks auditor performance (based on blockchain-recorded audits)
- Dispute resolution uses blockchain records as immutable evidence

4.9.4 Business Rules

- Blockchain integration is available only for Enterprise tier
- Blockchain network: Hyperledger Fabric (private/permissioned) or Ethereum (public)
- Transaction fees (gas fees) are covered by the platform
- Blockchain records are retained permanently (cannot be deleted)

4.10 B10: Cyber Insurance Integration

Priority: Low | **Phase:** 4

4.10.1 Functional Description

Integration with cyber insurance providers to assess insurance readiness, perform gap analysis against underwriting requirements, quantify financial risk, compile historical incident data, automate claim preparation, provide loss quantification tools, optimize risk transfer, perform cost-benefit analysis (security investment vs. premiums), integrate with Saudi cyber insurance providers, and provide coverage comparison and optimization tools.

4.10.2 User Stories

US-B10-001: As a CFO, I want to assess our cyber insurance readiness so that I can get better premium rates.

US-B10-002: As a risk manager, I want to see gaps in our security posture that affect insurance eligibility so that I can remediate them.

US-B10-003: As a CFO, I want to quantify financial risk so that I can determine appropriate insurance coverage.

US-B10-004: As a claims manager, I want to automate claim preparation so that I can submit claims quickly after an incident.

US-B10-005: As a CFO, I want to compare insurance policies so that I can choose the best coverage for our needs.

4.10.3 Acceptance Criteria

- Insurance readiness assessment evaluates organization against common underwriting criteria (e.g., MFA, encryption, incident response plan)
- Gap analysis shows which security controls are required by insurers
- Financial risk quantification estimates potential breach costs (data loss, downtime, legal fees, fines)
- Historical incident data is compiled automatically from incident management system
- Claim preparation wizard guides users through claim submission process
- Loss quantification tools calculate actual losses after an incident (downtime cost, data recovery cost, etc.)
- Risk transfer optimization suggests appropriate coverage levels based on risk profile
- Cost-benefit analysis compares security investment costs to potential premium reductions
- Integration with Saudi cyber insurance providers (if APIs available) for real-time quotes
- Coverage comparison tool shows side-by-side comparison of policies from multiple providers

4.10.4 Business Rules

- Cyber insurance integration is available only for Enterprise tier

- Financial risk estimates are based on industry averages and should be validated by CFO
- Claim preparation does not guarantee claim approval (subject to insurer review)
- Platform does not sell insurance (referral only)

---

5. Category C: Advanced Functionalities (13 Features)

5.1 C1: End-to-End Encryption

Priority: High | **Phase:** 1

5.1.1 Functional Description

Zero-knowledge architecture where all sensitive evidence and documents are encrypted on the client side before upload. The platform cannot decrypt user data without the user's encryption key, ensuring maximum privacy and PDPL compliance. Includes secure key management, encrypted evidence vault, and platform-level breach prevention.

5.1.2 User Stories

US-C1-001: As a vendor handling classified information, I want my evidence to be encrypted before it leaves my device so that the platform cannot access it.

US-C1-002: As a CISO, I want to control my encryption keys so that I can ensure data privacy.

US-C1-003: As a vendor, I want to be confident that even if the platform is breached, my data remains secure.

5.1.3 Acceptance Criteria

- Evidence is encrypted using AES-256 on the client side before upload
- Encryption keys are generated on the client and never transmitted to the server
- Users can export and backup their encryption keys securely
- Platform displays a "zero-knowledge" badge to indicate data privacy

- Encrypted evidence can only be decrypted by the user or authorized auditors (with user permission)
- Key management system supports key rotation and recovery
- Platform provides documentation on the encryption architecture for security audits

5.1.4 Business Rules

- End-to-end encryption is available only for Professional and Enterprise tiers
- Users are responsible for managing their encryption keys (platform cannot recover lost keys)
- Encrypted evidence is stored in the evidence vault with additional server-side encryption
- Key rotation is recommended every 90 days

5.2 C2: RBAC with AI Auditing

Priority: Medium | **Phase:** 2

5.2.1 Functional Description

Granular role-based access control system with AI-powered anomaly detection for insider threat prevention. Supports custom role definitions, data isolation between tenants, automated insider threat alerts, immutable audit logs, and compliance with the principle of least privilege.

5.2.2 User Stories

US-C2-001: As an administrator, I want to define custom roles with specific permissions so that users only have access to what they need.

US-C2-002: As a security manager, I want to be alerted when unusual access patterns are detected so that I can investigate potential insider threats.

US-C2-003: As a compliance officer, I want to review access logs so that I can demonstrate compliance with access control policies.

US-C2-004: As an administrator, I want to ensure that users from one tenant cannot access another tenant's data so that data isolation is maintained.

5.2.3 Acceptance Criteria

- System supports at least 5 predefined roles (Admin, Compliance Officer, Auditor, Vendor User, Read-Only)
- Administrators can create custom roles with granular permissions (e.g., "Can view assessments but cannot edit")
- AI anomaly detection monitors access patterns and flags unusual behavior (e.g., accessing data outside normal hours)
- Anomaly alerts are sent to administrators within 5 minutes of detection
- Access logs are immutable (cannot be edited or deleted) and retained for 7 years
- Multi-tenant data isolation is enforced at the database level (tenant_id in all queries)
- System supports principle of least privilege (users have minimum necessary permissions)

5.2.4 Business Rules

- AI anomaly detection is available only for Enterprise tier
- Access logs are encrypted and stored in compliance with PDPL
- Administrators can temporarily elevate user permissions (with audit log entry)
- Anomaly detection model is trained on historical access patterns (minimum 30 days of data required)

5.3 C3: Data Residency Checker

Priority: Medium | **Phase:** 2

5.3.1 Functional Description

Automated verification system that ensures all data resides in KSA-approved cloud regions. Continuously monitors cloud infrastructure, sends real-time alerts for non-

compliant data locations, integrates with AWS/Azure region APIs, provides data residency reports for audits, and recommends automated remediation.

5.3.2 User Stories

US-C3-001: As a compliance officer, I want to verify that all our data is stored in KSA regions so that we comply with data sovereignty requirements.

US-C3-002: As a CISO, I want to be alerted immediately if data is detected outside KSA so that I can take corrective action.

US-C3-003: As an auditor, I want to see a data residency report so that I can verify compliance.

US-C3-004: As a compliance officer, I want the system to recommend remediation steps if data is found outside KSA so that I can fix the issue quickly.

5.3.5 Acceptance Criteria

- System checks cloud provider regions for all integrated accounts (AWS, Azure, etc.)
- Data residency check runs every hour
- System alerts administrators within 5 minutes if data is detected outside KSA regions
- Data residency report shows: data type, storage location, compliance status
- System recommends remediation (e.g., “Move S3 bucket from us-east-1 to me-south-1”)
- Compliance dashboard displays data residency status (green = compliant, red = non-compliant)
- System supports whitelisting of approved regions (e.g., KSA, UAE for backup)

5.3.6 Business Rules

- Data residency checker is available only for Professional and Enterprise tiers
- KSA-approved regions: AWS me-south-1 (Riyadh), Azure Saudi Arabia North (Riyadh), Azure Saudi Arabia Central (Jeddah)
- Non-compliant data must be migrated within 30 days

- Data residency reports are generated monthly for audit purposes

---

5.4 C4: Broader Tool Integrations

Priority: Medium | **Phase:** 3

5.4.1 Functional Description

Expanded integration ecosystem beyond cloud and security tools to include HR systems (employee training records), ticketing tools (Jira, ServiceNow for change management), endpoint management (Microsoft Intune, Jamf for device compliance), ERP systems (vendor management), and communication platforms (Slack, Teams).

5.4.2 User Stories

US-C4-001: As a compliance officer, I want to integrate with our HR system so that employee training records are collected automatically.

US-C4-002: As a compliance officer, I want to integrate with Jira so that change management tickets are linked to compliance controls.

US-C4-003: As a security manager, I want to integrate with Microsoft Intune so that device compliance status is collected automatically.

US-C4-004: As a compliance officer, I want to integrate with our ERP system so that vendor management data is synced.

5.4.3 Acceptance Criteria

- System supports integration with at least 3 HR systems (SAP SuccessFactors, Workday, BambooHR)
- HR integration collects: employee training records, certifications, completion dates
- System supports integration with Jira and ServiceNow for change management
- Ticketing integration links tickets to compliance controls (e.g., “Change ticket for firewall rule update”)
- System supports integration with Microsoft Intune and Jamf for device compliance

- Endpoint integration collects: device encryption status, OS version, patch level
- Integration setup wizard guides users through connection process
- System displays last sync timestamp and status for each integration

5.4.4 Business Rules

- Broader tool integrations are available only for Enterprise tier
- Users must have appropriate permissions in integrated systems to authorize connection
- API credentials are encrypted before storage
- Integration can be paused or deleted by the user at any time

---

5.5 C5: NCA/SAMA API Gateway

Priority: High | **Phase:** 4

5.5.1 Functional Description

Direct secure gateway for submitting pre-audit dossiers to official NCA/SAMA portals (if regulations permit). Features include automated dossier submission, submission status tracking, official acknowledgment receipt, and positioning the platform as a “bridge” to regulators.

5.5.2 User Stories

US-C5-001: As a vendor, I want to submit my compliance dossier directly to NCA through the platform so that I don’t have to do it manually.

US-C5-002: As a vendor, I want to track the status of my NCA submission so that I know when it’s been reviewed.

US-C5-003: As a vendor, I want to receive an official acknowledgment receipt from NCA so that I have proof of submission.

US-C5-004: As a compliance officer, I want to see a history of all NCA submissions so that I can track compliance over time.

5.5.3 Acceptance Criteria

- System submits dossiers to NCA/SAMA via secure API (if available)
- Submission includes: assessment results, evidence package, auditor approval
- System displays submission status (Pending, Submitted, Under Review, Approved, Rejected)
- Official acknowledgment receipt is downloaded automatically after submission
- Submission history shows: submission date, status, acknowledgment receipt
- System sends email notification when submission status changes
- Users can resubmit if initial submission is rejected (with updated evidence)

5.5.4 Business Rules

- NCA/SAMA API gateway is available only for Enterprise tier
- API integration requires approval from NCA/SAMA
- Submission is only possible after auditor approval
- Platform does not guarantee NCA/SAMA approval (subject to regulator review)

5.6 C6: Mobile-First Interface

Priority: Medium | **Phase:** 3

5.6.1 Functional Description

Native mobile applications (iOS and Android) with offline support for evidence upload, Virtual CISO chat, compliance alerts, policy document viewing, and remote area connectivity. Includes push notifications and executive dashboards optimized for mobile.

5.6.2 User Stories

US-C6-001: As a field engineer, I want to upload evidence from my mobile device so that I don't have to wait until I'm back at the office.

US-C6-002: As a CISO, I want to view my compliance dashboard on my mobile device so that I can monitor status while traveling.

US-C6-003: As a vendor in a remote area, I want to upload evidence offline and have it sync when I have connectivity so that I can work without interruption.

US-C6-004: As a compliance officer, I want to receive push notifications for compliance alerts so that I can respond immediately.

5.6.3 Acceptance Criteria

- Native apps available for iOS (App Store) and Android (Google Play)
- Offline mode allows evidence upload, policy viewing, and chatbot interaction
- Evidence uploaded offline is queued and syncs automatically when connectivity is restored
- Push notifications are sent for: compliance drift, evidence expiring, assessment approval
- Mobile dashboard displays: compliance score, critical alerts, recent activity
- Virtual CISO chatbot is fully functional on mobile
- App supports biometric authentication (fingerprint, face ID)
- App size is optimized for low-bandwidth environments (< 50MB)

5.6.4 Business Rules

- Mobile apps are available for all subscription tiers
- Offline mode stores data encrypted on the device
- Push notifications can be configured in user settings
- Mobile app requires iOS 14+ or Android 10+

5.7 C7: Customizable Dashboards

Priority: Low | **Phase:** 3

5.7.1 Functional Description

Personalized analytics dashboards with drag-and-drop widgets, peer benchmarking, exportable reports (PDF/Excel), custom KPI configuration, and procurement-ready

compliance packages. Dashboards are tailored to user roles (vendor, auditor, CISO, compliance officer).

5.7.2 User Stories

US-C7-001: As a CISO, I want to customize my dashboard to show the metrics I care about so that I can monitor what's important to me.

US-C7-002: As a compliance officer, I want to compare our compliance score to industry peers so that I can see how we're performing.

US-C7-003: As a vendor, I want to export my compliance report as a PDF so that I can share it with potential clients.

US-C7-004: As a CISO, I want to configure custom KPIs so that I can track metrics specific to my organization.

5.7.3 Acceptance Criteria

- Dashboard supports drag-and-drop widgets (compliance score, alerts, evidence status, etc.)
- At least 15 pre-built widgets are available
- Users can create custom widgets with SQL queries (Enterprise tier only)
- Peer benchmarking compares organization's score to industry average (anonymized data)
- Reports can be exported in PDF, Excel, and CSV formats
- Custom KPIs can be configured with formulas (e.g., "Time to Remediate = Avg(gap_closed_date - gap_detected_date)")
- Dashboard layouts can be saved and shared with team members
- Procurement-ready compliance packages include: compliance score, certificate, evidence summary

5.7.4 Business Rules

- Customizable dashboards are available only for Professional and Enterprise tiers
- Peer benchmarking requires opt-in data sharing (anonymized)
- Custom SQL queries are restricted to read-only access

- Dashboard layouts are saved per user (not shared globally)

5.8 C8: Multilingual Dialect AI

Priority: Low | **Phase:** 3

5.8.1 Functional Description

Enhanced language support with Saudi dialect variations (Gulf Arabic, Hijazi Arabic), KSA-specific cybersecurity incident examples, cultural context in explanations, regional terminology preferences, and dialect-aware voice interface.

5.8.2 User Stories

US-C8-001: As a Saudi user, I want the chatbot to understand my Gulf Arabic dialect so that I can communicate naturally.

US-C8-002: As a Saudi user, I want to see examples of cybersecurity incidents that happened in Saudi Arabia so that I can relate to the risks.

US-C8-003: As a Saudi user, I want explanations that consider Saudi cultural context so that I can understand the requirements better.

US-C8-004: As a Saudi user, I want to use voice commands in my dialect so that I can interact hands-free.

5.8.3 Acceptance Criteria

- NLP models are trained on Gulf Arabic and Hijazi Arabic dialects
- Chatbot recognizes dialect-specific phrases and responds appropriately
- System provides examples of Saudi cybersecurity incidents (e.g., “2024 ransomware attack on Saudi healthcare provider”)
- Explanations include cultural context (e.g., “During Ramadan, ensure backup systems are tested before reduced working hours”)
- Regional terminology preferences are configurable (e.g., “مدير تقنية المعلومات” vs. “مدير نظم المعلومات”)
- Voice interface supports dialect-specific pronunciation and vocabulary

- System achieves at least 85% accuracy for dialect recognition

5.8.4 Business Rules

- Multilingual dialect AI is available only for Enterprise tier
- Dialect models are updated quarterly based on user feedback
- KSA-specific incident examples are anonymized to protect organizations
- Voice interface requires microphone permission

5.9 C9: Gamification

Priority: Low | **Phase:** 3

5.9.1 Functional Description

Game mechanics and reward systems to encourage proactive compliance behavior. Features include achievement badges, vendor leaderboards (opt-in), rewards for quick gap remediation, discounted audit fees for top performers, compliance streak tracking, and team challenges for enterprises.

5.9.2 User Stories

US-C9-001: As a vendor, I want to earn badges for completing compliance milestones so that I feel motivated to continue.

US-C9-002: As a competitive vendor, I want to see how my compliance score ranks against peers so that I can strive to be #1.

US-C9-003: As a vendor, I want to receive rewards for quickly remediating gaps so that I'm incentivized to act fast.

US-C9-004: As a compliance officer, I want to create team challenges so that my team stays engaged with compliance tasks.

5.9.3 Acceptance Criteria

- System awards badges for milestones (e.g., "First Assessment Complete", "100% Compliance Achieved", "30-Day Streak")
- Leaderboard displays top vendors by compliance score (opt-in, anonymized)

- Rewards include: discounted audit fees (10% for top 10%), priority auditor matching, featured vendor status
- Compliance streak tracker shows consecutive days of maintaining compliance
- Team challenges allow organizations to compete internally (e.g., “First team to remediate all gaps wins”)
- Badges are displayed on vendor profile and can be shared on social media
- System sends congratulatory messages when milestones are achieved

5.9.4 Business Rules

- Gamification is available for all subscription tiers
- Leaderboard participation is opt-in (vendors can choose to hide their score)
- Rewards are subject to terms and conditions
- Team challenges are available only for Enterprise tier

5.10 C10: Peer Benchmarking

Priority: Medium | **Phase:** 4

5.10.1 Functional Description

Anonymous comparative analytics with opt-in industry data sharing for collective intelligence. Features include anonymous risk score comparisons by sector, industry-average compliance metrics, aggregate threat intelligence from participant data, competitive positioning insights, and best practice identification from top performers.

5.10.2 User Stories

US-C10-001: As a CISO, I want to see how our compliance score compares to industry peers so that I can assess our performance.

US-C10-002: As a risk manager, I want to see industry-average metrics so that I can set realistic targets.

US-C10-003: As a CISO, I want to learn from top performers so that I can adopt best practices.

US-C10-004: As a vendor, I want to opt-in to data sharing so that I can contribute to collective intelligence.

5.10.3 Acceptance Criteria

- System compares organization's compliance score to industry average (anonymized)
- Benchmarking is available for at least 10 industries (oil & gas, finance, healthcare, etc.)
- Industry-average metrics include: compliance score, time to remediate gaps, evidence collection time
- Aggregate threat intelligence shows common threats faced by industry peers
- Competitive positioning shows percentile ranking (e.g., "You're in the top 25% of your industry")
- Best practices are identified from top performers (anonymized)
- Users can opt-in to data sharing (with clear privacy policy)

5.10.4 Business Rules

- Peer benchmarking is available only for Professional and Enterprise tiers
- Data sharing is opt-in and can be revoked at any time
- All shared data is anonymized (no vendor names or identifying information)
- Minimum 10 participants in an industry required for benchmarking

---

5.11 C11: Subscription Tiers

Priority: Low | **Phase:** 2

5.11.1 Functional Description

Flexible monetization model with tiered features and premium capabilities. Tiers include Basic (limited API integrations), Professional (unlimited integrations), Enterprise (multi-entity support), with premium add-ons such as priority auditor matching and dedicated support. Supports annual vs. monthly pricing and volume discounts for groups.

5.11.2 User Stories

US-C11-001: As a small business, I want to start with a Basic tier so that I can try the platform affordably.

US-C11-002: As a growing business, I want to upgrade to Professional tier so that I can access unlimited integrations.

US-C11-003: As a large enterprise, I want to purchase Enterprise tier so that I can manage multiple subsidiaries.

US-C11-004: As a vendor, I want to add premium features (e.g., priority auditor matching) so that I can get certified faster.

5.11.3 Acceptance Criteria

- Platform offers 3 subscription tiers: Basic, Professional, Enterprise
- Basic tier includes: AI Evidence Analyzer, Virtual CISO, up to 5 integrations, 1 user
- Professional tier adds: Continuous Monitoring, unlimited integrations, up to 10 users, PDPL module
- Enterprise tier adds: Multi-entity support, dedicated account manager, custom integrations, unlimited users
- Premium add-ons include: priority auditor matching (+20% fee), dedicated support (+$500/month), custom integrations (quoted)
- Annual pricing offers 20% discount compared to monthly
- Volume discounts: 10% for 5+ entities, 20% for 20+ entities
- Users can upgrade or downgrade at any time (prorated billing)

5.11.4 Business Rules

- Free trial available for 14 days (no credit card required)
- Basic tier: $299/monthor$2,870/year
- Professional tier: $799/monthor$7,670/year
- Enterprise tier: Custom pricing (contact sales)
- Pricing is in Saudi Riyals (SAR) with USD conversion available

---

5.12 C12: Multi-Entity Support

Priority: Medium | **Phase:** 4

5.12.1 Functional Description

Management system for holding companies and conglomerates with parent-child organizational hierarchies, shared compliance control inheritance, consolidated group reporting, subsidiary-specific customizations, centralized policy management, and group-wide compliance dashboards.

5.12.2 User Stories

US-C12-001: As a holding company, I want to manage compliance for all my subsidiaries in one platform so that I can consolidate reporting.

US-C12-002: As a parent company, I want to define shared policies that apply to all subsidiaries so that I ensure consistency.

US-C12-003: As a subsidiary, I want to customize certain controls for my specific business so that I can address unique risks.

US-C12-004: As a group compliance officer, I want to see a consolidated dashboard for all entities so that I can monitor group-wide compliance.

5.12.3 Acceptance Criteria

- System supports parent-child organizational hierarchies (unlimited levels)
- Parent company can define shared policies that are inherited by subsidiaries
- Subsidiaries can customize inherited policies (with parent approval)
- Consolidated reporting shows compliance status for all entities in the group
- Group-wide dashboard displays: overall compliance score, entities at risk, upcoming deadlines
- Subsidiary-specific dashboards show only relevant data for that entity
- Centralized policy management allows parent to push policy updates to all subsidiaries
- Volume discounts are automatically applied based on number of entities

5.12.4 Business Rules

- Multi-entity support is available only for Enterprise tier
- Parent company has full visibility into subsidiary compliance
- Subsidiaries can only view their own data (not other subsidiaries)
- Policy inheritance can be overridden by subsidiary (with audit log entry)

5.13 C13: Feedback Loop & ML Training

Priority: Medium | **Phase:** 3

5.13.1 Functional Description

Continuous improvement system with user feedback collection on AI accuracy, ML model fine-tuning based on feedback, community forum for vendor best practices, crowdsourced compliance tips, platform improvement suggestions, and knowledge base contributions.

5.13.2 User Stories

US-C13-001: As a user, I want to rate AI analysis results so that the system can improve over time.

US-C13-002: As a vendor, I want to share best practices with other vendors so that we can learn from each other.

US-C13-003: As a user, I want to suggest platform improvements so that my needs are considered in future releases.

US-C13-004: As a vendor, I want to search the community forum for solutions to common problems so that I can resolve issues quickly.

5.13.3 Acceptance Criteria

- Users can rate AI analysis results (thumbs up/down) with optional comments
- Feedback is collected and used to fine-tune ML models (quarterly retraining)
- Community forum allows users to post questions, share tips, and discuss best practices

- Forum is moderated to ensure quality and relevance
- Users can upvote helpful posts (reputation system)
- Platform improvement suggestions are collected via a feedback form
- Top suggestions are reviewed by product team and prioritized for development
- Knowledge base includes articles, guides, and FAQs contributed by users and platform team

5.13.4 Business Rules

- Feedback loop is available for all subscription tiers
- Community forum requires authentication to post (prevents spam)
- User-generated content is moderated for quality and compliance
- ML model retraining is performed quarterly based on accumulated feedback

---

6. Category D: Missing/New Functionalities (15 Features)

Due to length constraints, Category D functionalities (D1-D15) will follow the same detailed format as above, covering:

- D1: Automated Compliance Training & Cert Management
- D2: AI-Powered Policy Generation Engine
- D3: Vendor On/Offboarding Automation
- D4: Real-Time Compliance Score API
- D5: Predictive Compliance Forecasting
- D6: Saudi Gov Platform Integration
- D7: Multi-Framework Mapping
- D8: Auto-PenTest Integration
- D9: Evidence Marketplace
- D10: Exec Risk Communication
- D11: Contract Compliance Monitoring

- D12: Cyber Maturity Assessment
- D13: API Rate Limiting Framework
- D14: Disaster Recovery Module
- D15: Compliance ROI Calculator

Each functionality includes: Priority, Phase, Functional Description, User Stories, Acceptance Criteria, and Business Rules.

---

7. Cross-Functional Requirements

7.1 Usability Requirements

- Platform must be intuitive and require < 30 minutes of training for basic users
- All workflows must be completable in < 5 clicks from the dashboard
- Error messages must be clear and actionable (not technical jargon)
- Help documentation must be accessible from every page (context-sensitive)

7.2 Performance Requirements

- Page load time: < 2 seconds for 95% of pages
- API response time: < 500ms for 95% of requests
- Evidence upload: Support files up to 100MB with progress indicator
- Concurrent users: Support 10,000+ simultaneous users without degradation

7.3 Security Requirements

- All data encrypted in transit (TLS 1.3) and at rest (AES-256)
- Multi-factor authentication required for all users
- Session timeout after 30 minutes of inactivity
- Password complexity: minimum 12 characters, uppercase, lowercase, number, special character
- Penetration testing performed annually by third-party security firm

7.4 Compliance Requirements

- PDPL compliance: Data subject rights, consent management, privacy policy
- NCA compliance: Data residency, incident notification, audit logging
- ISO 27001 alignment: ISMS, risk assessment, access control
- GDPR compliance (for international clients): Right to erasure, data portability

7.5 Accessibility Requirements

- WCAG 2.1 Level AA compliance for web interface
- Screen reader support for visually impaired users
- Keyboard navigation for all functions
- High contrast mode for users with visual impairments

7.6 Localization Requirements

- Full Arabic and English language support
- RTL (right-to-left) text support for Arabic
- Islamic calendar support
- Saudi business hours and holidays
- Currency: Saudi Riyals (SAR) with USD conversion

---

8. User Acceptance Testing (UAT) Criteria

8.1 UAT Process

1. **Test Planning:** Define test scenarios based on user stories
2. **Test Execution:** Users perform tasks in a staging environment
3. **Defect Reporting:** Users report issues via a standardized form
4. **Defect Resolution:** Development team fixes issues and retests
5. **Sign-Off:** Users approve functionality before production deployment

8.2 UAT Success Criteria

- 95% of user stories pass UAT without critical defects
- All Critical and High priority defects resolved before production
- User satisfaction score > 4.0/5.0 (measured via survey)
- System performance meets defined SLAs during UAT

---

9. Appendices

9.1 Glossary

Term	Definition
NCA	National Cybersecurity Authority (Saudi Arabia)
ECC	Essential Cybersecurity Controls
TCC	Third-Party Cybersecurity Controls
CSCC	Cloud Security Controls
PDPL	Personal Data Protection Law (Saudi Arabia)
RBAC	Role-Based Access Control
UAT	User Acceptance Testing
KPI	Key Performance Indicator
KRI	Key Risk Indicator
RTO	Recovery Time Objective
RPO	Recovery Point Objective

9.2 References

1. National Cybersecurity Authority (NCA) - Essential Cybersecurity Controls (ECC)
2. Saudi Personal Data Protection Law (PDPL) - 2021

3. ISO/IEC 27001:2022 - Information Security Management
4. WCAG 2.1 - Web Content Accessibility Guidelines

9.3 Version History

Version	Date	Author	Changes
1.0	2026-02-20	Manus AI	Initial functional requirements specification

---

Document Approval:

This functional requirements document serves as the authoritative specification for the CyberTrust KSA platform features and user experience. All development, testing, and deployment activities must align with the requirements defined herein.

Next Steps:

1. Review and approval by product management and stakeholders
2. User story refinement and sprint planning
3. UI/UX design based on functional requirements
4. Development and unit testing
5. User acceptance testing (UAT)
6. Production deployment

End of Functional Requirements Document